

NationalBank Reserve — Red Team Engagement

Checkpoint 4: Social Engineering + Detection Evasion (Lab)

Analyst: Mustafa Musa Ahmed
Date: 2026
Classification: Authorized Lab Environment Only

1. Executive Summary

This checkpoint simulated a realistic phishing campaign against a lab-provisioned employee account and evaluated endpoint detection evasion techniques against a local malware signature engine. A credential-harvesting email was delivered successfully, the target clicked the link, and credentials were captured by the Gophish platform. Three malware payloads were generated with increasing obfuscation and scanned; results demonstrate that popular encoders do not guarantee evasion, while custom byte-level obfuscation can defeat signature-only detection.

Key outcomes: - 1/1 phishing emails delivered - 1/1 target clicked the link (100%) - 1/1 credential submission captured - 2/3 payloads bypassed the signature scanner - Full MITRE ATT&CK mapping delivered

Overall risk: HIGH — human and technical controls in the lab environment were bypassed within minutes.

2. Scope & Rules of Engagement

Item	Value
Target	Lab environment simulating NationalBank Reserve
In-scope assets	DVWA container (web), MailHog (SMTP), Kali attacker host
Out-of-scope	Any production network, real user data, third-party systems
Allowed	OSINT, phishing simulation, payload generation, local scanning
Prohibited	DoS, data exfiltration, physical intrusion, real user targeting
Authorization	Internship capstone, authorized lab only

3. Attack Narrative

Phase	Activity	Tool	Result
1. Reconnaissance	Enumerated DVWA web target	Nmap, Nikto	Found outdated Apache, missing headers, /config/ directory indexing
2. Infrastructure	Stood up MailHog + Gophish	Docker, Gophish	Phishing infrastructure ready
3. Pretext	Crafted “Password Expiry” email	Gophish templates	Template + landing page created
4. Delivery	Sent campaign to lab target	Gophish SMTP	Email delivered
5. Click	Simulated victim click	curl	Link clicked, Gophish recorded event
6. Capture	Submitted test credentials	curl	Username + password captured in Gophish
7. Evasion	Generated and tested payloads	msfvenom, Python, ClamAV	2/3 bypassed signature detection

Time to compromise: **under 15 minutes** from campaign launch to credential capture.

4. Findings & MITRE ATT&CK Mapping

4.1 Phishing Findings

ID	Finding	Severity	MITRE TTP	Evidence
P-01	Phishing email delivered from spoofed sender	HIGH	T1566, T1566.002	mailhog_messages.json

ID	Finding	Severity	MITRE TTP	Evidence
P-02	Target clicked credential-harvesting link	HIGH	T1204.002	events_db.txt
P-03	Credentials submitted and captured	CRITICAL	T1566, T1056.003	events_db.txt
P-04	No email gateway / DMARC / SPF blocking detected	HIGH	T1566.001	gophish_startup.log

4.2 Detection Evasion Findings

ID	Finding	Severity	MITRE TTP	Evidence
E-01	Unencoded payload evaded signature scan	MEDIUM	T1027	detect_base.txt
E-02	shikata_ga_nai 10x encoder was DETECTED	INFORMATIONAL	T1027.002	detect_encoded.txt
E-03	Custom XOR obfuscation evaded signature scan	HIGH	T1027	detect_obfuscated.txt
E-04	Signature-based AV alone insufficient	HIGH	T1027	all detect_*.txt

4.3 MITRE ATT&CK Coverage Summary

Tactic	Technique	ID
Reconnaissance	Active Scanning	T1595
Reconnaissance	Gather Victim Host Info	T1592

Tactic	Technique	ID
Initial Access	Phishing	T1566
Initial Access	Spearphishing Link	T1566.002
Execution	User Execution	T1204.002
Defense Evasion	Obfuscated Files or Information	T1027
Defense Evasion	Software Packing	T1027.002
Resource Development	Develop Capabilities: Malware	T1587.001
Credential Access	Input Capture: Web Portal	T1056.003

5. Detection Evasion Results

Sample	SHA-256 (first 16)	Size	Strings	Entropy	ClamAV Result
rev_shell.exe	5648ebf3fe2ef97f68	97168	34	1.2755	OK
encoded_shell.exe	16d30a8679447680	7680	29	1.6747	DETECTED — Win.Trojan.MSShellcode-6360728-0
obfuscated_shell.exe	011e2cddf8be25080	79360	8	1.6747	OK
eicar.txt	131f95c51cc81946	—	—	—	DETECTED
(control)	—	—	—	—	— Eicar-Signature

Key insight: The 10x shikata_ga_nai encoder did NOT help evasion against ClamAV — in fact it made the payload detectable due to its own well-known signature. Custom XOR obfuscation removed all recognizable strings and defeated signature detection. This illustrates why signature-only AV is insufficient against even beginner-level obfuscation.

6. Defensive Recommendations

Priority	Timeline	Action
Immediate	24h	Deploy email gateway with DMARC, SPF, DKIM enforcement
Immediate	24h	Block external senders spoofing internal domains

Priority	Timeline	Action
Immediate	24h	Enable URL rewriting and detonation in email security
Short-term	1 week	Replace signature-only AV with EDR solution
Short-term	1 week	Enable AMSI logging and script block logging
Short-term	1 week	Roll out phishing-resistant MFA (FIDO2) for privileged users
Short-term	1 week	Conduct quarterly phishing simulation and training
Long-term	1 month	Implement application allowlisting on endpoints
Long-term	1 month	Establish 24/7 SOC with behavioral detection rules
Long-term	1 month	Deploy deception technology (honeytokens, canary files)
Long-term	1 month	Formal red team / blue team exercise cadence

7. Evidence Appendix

Evidence File	Description
evidence/nmap_100.txt	Initial subnet discovery
evidence/nikto_dvwa.txt	DVWA web vulnerability scan
evidence/dvwa_headers.txt	HTTP response headers
evidence/dvwa_dirs.txt	Directory brute force results
evidence/gophish/api_key.txt	Gophish API key extraction (lab only)
evidence/gophish/smtp.json	Sending profile configuration
evidence/gophish/template.json	Phishing email template
evidence/gophish/page.json	Credential-harvesting landing page
evidence/gophish/campaign.json	Campaign launch record
evidence/gophish/mailhog_messages.json	Delivered phishing email
evidence/gophish/email_body_clean.txt	Email body (decoded)
evidence/gophish/captured_result.json	Click + credential capture proof

Evidence File	Description
evidence/gophish/events_db.txt	Gophish event log (full timeline)
evidence/payload_hashes.txt	SHA-256 of all payloads
evidence/payload_entropy.txt	Entropy measurements
evidence/payload_string_counts.txt	String count comparison
evidence/detect_base.txt	ClamAV scan — base payload
evidence/detect_encoded.txt	ClamAV scan — encoded payload
evidence/detect_obfuscated.txt	ClamAV scan — obfuscated payload
evidence/detect_eicar_control.txt	ClamAV scan — EICAR control
evidence/PHASE2_SUMMARY.txt	Phase 2 summary
evidence/PHASE3_SUMMARY.txt	Phase 3 summary

8. Conclusion

The lab successfully demonstrated the complete social engineering kill chain: delivery → click → credential capture. Detection evasion testing showed that signature-only defenses are trivially bypassed by beginner-level obfuscation, reinforcing the need for behavioral EDR, phishing-resistant MFA, and robust email gateway controls. All activities were performed within the authorized lab environment and are documented for defensive improvement.

Next phase: Checkpoint 5 — Executive Pentest Report + Defensive Roadmap.

Prepared for authorized laboratory red team exercise. All evidence retained in the associated GitHub repository.